

Legal Source PDF: DE_CERTIFICATION_ROADMAP_CLISONIX.md

docs\legal\de\DE_CERTIFICATION_ROADMAP_CLISONIX.md

Generated for legal review and attorney handoff

Germany Certification and Compliance Roadmap

Document type: Certification planning pack for Germany and EU market readiness

Date: 2026-05-09

Legal Note

This is an engineering and governance preparation roadmap, not legal certification advice.

1. Recommended Certification Tracks

Track A (Immediate, broad trust baseline)

ISO/IEC 27001 (ISMS)

ISO/IEC 27701 (privacy extension) optional but recommended

VAPT + secure SDLC evidence package

Track B (AI governance)

ISO/IEC 42001 (AI management system)

EU AI Act readiness dossier (risk classification, human oversight, logging, post-market monitoring)

Track C (German cloud/public-sector credibility)

BSI C5 attestation preparation (if cloud/SaaS target includes DE enterprise or public-sector buyers)

Track D (if healthcare workflow is intended)

Medical device pre-assessment under MDR + IEC 62304 + ISO 14971 + ISO 13485 path

Clinical safety and performance documentation as required by device class

2. What Your Current Stack Already Supports

Runtime security profiles and policy actions:

sdist/clx-ai/clx/security/monitor.py line 15

sdist/clx-ai/clx/security/monitor.py line 162

Traceable processing pipeline with security gates:

sdist/clx-ai/clx/core.py line 61

sdist/clx-ai/clx/core.py line 108

Metrics and event logging in CLX.I:

clx_i_service.py line 58

clx_i_service.py line 68

clx_i_service.py line 153

clx_i_service.py line 170

No-fake-data and atomic persistence controls:

sdist/clx-ai/examples/ecosystem_ops_10min.py line 8

sdist/clx-ai/examples/ecosystem_ops_10min.py line 68

3. Certification Deliverables to Prepare

ISMS (ISO 27001)

Information security policy set.

Asset inventory and data flow map.

Risk register and treatment plan.

Access control, key management, incident response SOPs.

Logging, monitoring, backup/restore evidence.

Internal audit reports + management review minutes.

AI Governance (ISO 42001 / EU AI Act readiness)

AI system inventory and intended-use statements.

Risk management records per model/service.

Data governance and provenance records.

Performance monitoring, drift detection, and override procedures.

Transparency notices and human oversight procedures.

BSI C5 readiness

Control mapping from your existing controls to C5 domains.

Evidence collection matrix (technical + organizational).

Gap closure plan with owners and deadlines.

4. 90-Day Execution Plan

Days 1-30

Define scope boundary (which services and environments).

Build unified control matrix (27001 + 42001 + C5 overlap).

Start evidence repository and naming convention.

Days 31-60

Complete risk assessment and policy baseline.

Run tabletop incident exercise and access review.

Close high-risk technical gaps (auth, logs, backup, monitoring).

Days 61-90

Internal pre-audit and corrective actions.

Select certification body / audit partner.

Freeze evidence package and schedule stage-1 audit.

5. Germany-Specific Practical Next Steps

Engage a DE-based Patentanwalt for patent filing finalization.

Engage a DE/EU certification body for ISO 27001 scoping call.

Run a legal screening for EU AI Act role (provider/deployer/importer).

If health claims are planned, run MDR classification with notified-body strategy early.

6. Priority Order (Recommended)

Patent filing draft finalization (to secure priority date).

ISO 27001 groundwork (improves trust and procurement readiness).

ISO 42001 + AI Act documentation layer.

BSI C5 mapping for enterprise/public-sector opportunities.

This roadmap follows secure SDLC practices and includes VAPT checkpoints before release.

The package is distributed as an sdist and validated in CI for reproducible builds.

Legal review with a Patentanwalt is required before filing and publication, based on counsel advice.

```
{  
  "cSpell.words": [  
    "VAPT",  
    "SDLC",  
    "sdist",  
    "Patentanwalt"  
  ]  
}
```